

A Case Study of the 2025 Marks & Spencer Ransomware Attack: Cybersecurity Vulnerabilities, Operational Disruption and Organizational Response

A Study of the Cyberattack, Its Impact, Response and Cybersecurity Lessons

Research Paper / Case Study

Submitted in partial fulfilment of the requirements for the
Bachelor of Computer Applications (BCA)

Submitted By

Atifa Asim
BCA – Final Year
City College, Jayanagar
Bengaluru

Submitted To

[Ms. Chandana]
Department of Computer Applications
City College, Jayanagar
Bengaluru

Academic Year

2026–2027

Date of Submission: _____8/10/2026_____

ABSTRACT

Since digital technology is being used more and more, cybersecurity has become a major issue for large businesses. Stores like Marks & Spencer (M&S) make use of digital systems for online shopping, for payments, for managing their stock, for logistics and for providing customer services. As these systems are closely linked, a cyberattack can have an impact not only on the computer systems but also on normal business operations. In April 2025 M&S had a serious cyber incident which disrupted a number of its services. As a precaution the company put some of its systems offline and temporarily halted online orders. The disruption also had an effect on warehouse and ordering procedures, so the company was forced to resort to manual methods in order to carry on with its operations. M&S later stated that some personal customer information had been obtained, even though usable details of payment cards and account passwords were not included. This case study looks at the M&S cyberattack, with emphasis on the nature of the incident, its possible technical features, the effect on business operations and on customers, and the actions taken by the company. It also considers the financial impact of the incident and the kind of cybersecurity measures that can help organisations prepare for similar attacks. M&S first estimated that the incident could reduce its operating profit for the 2025/26 financial year by about £300 million before taking into account mitigation, insurance and trading measures. The purpose of the study is to demonstrate that cybersecurity should be viewed not just as an IT issue but also as an important element of business continuity and organisational risk management.

Keywords: Cybersecurity, Ransomware, Marks & Spencer, Cyberattack, Data Security, Incident Response, Business Continuity.

INTRODUCTION

Cybersecurity isn't some abstract IT worry anymore. It's a day-to-day business risk, especially for retailers that run on tightly linked digital systems—webstores, payments, customer records, supply chains, stock control, internal comms, all of it. When one piece goes down, it rarely stays contained. Customers feel it. Staff feel it. Suppliers feel it. The knock-on effects spread fast. And with ransomware and similar attacks on the rise, the key question is how prepared organisations are to weather an attack and continue functioning. Marks and Spencer (M&S), one of the UK's biggest household-name retailers, got a harsh lesson in that in April. The company announced in April a serious cyber incident and said it is working to contain the situation, protect its systems and bring in external cybersecurity specialists to help. As events unfolded, M&S put online orders on pause across its website and apps, even though its physical stores kept trading. That split—stores open, digital channels disrupted—made one point painfully clear: a cyber incident can quickly turn into a full-blown operations problem, not just an “information security” issue. Customer data was caught up in the fallout as well. M&S later confirmed that attackers had taken some customer information, while saying that payment-card data and account passwords were not among the details. Further investigation, reporting and

parliamentary evidence have since painted a more detailed picture. M&S indicated that the attack had begun by targeting a third-party contractor, which is an uncomfortable reminder of the vulnerabilities posed by supply chains. The operational and financial damage wasn't small. M&S had to disconnect and re-establish parts of its technology estate and key services were disrupted including online ordering, click and collect and some in-store ordering processes. The larger number was a significant loss, for example an estimated impact on group profit of £ million for the / financial year. The cost of a major cyber-attack is hard to quantify but this illustrates a major risk for any company with a large online presence. The context of this case is therefore important because it reflects the challenge faced by many large organisations which have complex digital ecosystems. A major incident of this type has cascading effects across business processes and customer experience. The case study will examine how the incident unfolded and potential vectors for initial compromise and focus on the implications for managing third party risk. It will also consider the impact on operations and costs and how M&S responded and what this indicates for other firms in terms of prevention, preparation, response and resilience.



Fig 1

OBJECTIVES OF THE STUDY

The objective of this study is to investigate the ransomware cyber-attack that affected Marks and Spencer (M&S). In particular, the paper will focus on the following research aims:

1. To learn about the M&S ransomware case by investigating how the cyber-attack developed and impacted the organisation.
2. To identify the likely method of initial access used by M&S attackers and evaluate potential third-party access issues.
3. To analyse the ransomware attack impact on M&S's digital services, retail operations, customers, employees, and supply-chain processes.
4. To examine the data-security implications of this incident, including the risk of customer information exposure or theft.

5. To assess the Company's response to this cyber-security incident and evaluate the measures taken to eliminate the threat and protect the digital assets.
6. To estimate the financial and operational impact of this cyber-attack and understand how large businesses can be affected.
7. To identify the ransomware risks and vulnerabilities that led to this security breach and examine the threats of interconnected software solutions.
8. To derive cybersecurity-related recommendations and lessons learned for other big companies to improve ransomware prevention and incident response capabilities.

BACKGROUND

Marks & Spencer is a major British retailer operating across food, clothing, homeware. Beauty, an ecosystem of stores, warehouses, suppliers, websites, apps and technology underpinning them. With such a complex infrastructure, uptime is critical to ensuring continued operations and to safeguarding the security of the infrastructure itself. Prior to the cyber incident, M&S had already recorded a number of incidents across its technology ecosystem. The company's overall approach to technology had become increasingly complex, with some aspects of the technology infrastructure requiring urgent upgrade. On 1 April, M&S announced that it was responding to a sophisticated cyber incident, taking steps to protect its systems and operations from further impact. Prior to that, M&S had taken measures to restrict access to certain systems, in particular, moving some operations offline, and had engaged cybersecurity experts, as well as informing the appropriate regulators of the incident. However, M&S did not go into detail on the specifics of how the company was compromised to begin with. Over the following days, the situation was brought under control, with the disruption to operations escalating. By April M&S advised that customers were unable to place orders online, at least for the time being. This was a precautionary measure, which helped the company investigate the source of the disruption and deal with it while limiting the impact to its operations. While most elements of M&S's operations continued as normal, several digital services were impacted, in particular, online ordering and Click & Collect. The nature of the disruption was not a direct attack on M&S's own systems, but rather a third-party contractor who had access to the M&S technology infrastructure had been compromised first and acted as a conduit for the attack. This is an important distinction, as it helps illustrate the indirect nature of the attack, which may be much harder to prevent and detect. According to reports, social engineering played a significant part in enabling the attack. In practice, this means that human error or weak points in the system can be exploited to gain access to data and systems, even if they appear to be well-protected. There has been speculation as to who was behind the attack, with reports pointing towards the loosely connected collective known as Scattered Spider, responsible for a number of attacks attributed to ransomware. M&S's chairman Archie Norman mentioned in a parliamentary select committee that they believed DragonForce was behind the ransomware aspect of the incident. It appears the safest way to describe the situation and to deal with the fallout is for M&S to associate DragonForce with the ransomware element of the incident, and Scattered Spider with the reports that were published. I am not entirely sure but going into any more detail than that may be guessing at what specific people or organisations were involved, as the situation as it stands does not seem to identify those people or organisations with certainty. Aside from that, the attack resulted in M&S having to disconnect certain systems from the network in order to prevent further damage. This caused some significant disruption to its operations. As the

company continued to deal with the incident, its warehouse systems were also disconnected from the network. This caused some disruption to operations which were largely automated, such as forecasting and ordering stock supplies. I feel this part is easy to overlook when talking about the incident, but those workarounds may well have added significantly to the disruption experienced by the company. In other words, the various actions taken by the company allowed it to continue operating its stores despite the disruptions to its digital services. The online business was much more severely impacted, with its online ordering service unavailable for most of the duration. It should be noted that online clothing orders have since resumed on 10 June 2025, following nearly 46 days of disruption. M&S resumed its services gradually rather than attempting to restore all of them at once. The incident also involved the unauthorised acquisition of some customer information. M&S informed their customers that information had been acquired, and that it could include information such as contact details, dates of birth and online order history. It noted that the information acquired did not include usable payment-card details or account passwords and that at the time there was no evidence that the information had been shared. The implications of incidents impacted M&S's food, fashion, and logistics operations. The disruptions to the technology and warehouse systems resulted in a decrease in the range of products within some of M&S's food operations, resulting in increased waste and additional costs associated with the logistics. M&S, in its reporting anticipated that the incident could decrease the group profit by approximately £300 million during the 2025/26 year before any mitigation such as insurance and cost management takes effect. The final financial impact of the incident was evident in the subsequent reporting of M&S. Within the M&S 2026 annual results, the significant costs associated with incident recovery, risk management, and specialist support were recorded. The report noted £131.3 million of incident-related costs and £100 million of insurance proceeds associated with the incident. M&S responded by activating established business-continuity and incident-management procedures and working with specialist cybersecurity organisations to progressively rebuild or restore affected systems. In the meantime, rather than keeping all systems connected while the investigation continued the company took systems offline as a precaution and accelerated existing plans to upgrade its technology infrastructure, network connectivity, supply-chain systems and overall resilience. The M&S incident therefore presents more than a standard data-security breach, demonstrating the way in which a ransomware attack can evolve from initial compromise to impact across digital services, supply-chain processes and customer-facing operations. It also underlines the need to secure third-party relationships, prepare for system outages, ensure effective incident response management procedures and provide continuity of critical functions when digital infrastructure is unavailable. These factors make it a potentially valuable case for examining the technical, operational and organisational impact of a ransomware attack.

PROBLEM STATEMENT

The increasing dependence of large retail organizations on the internet has created cybersecurity challenges. Interrelated systems that facilitate online sales, payments, inventory, warehousing, supply chains, customer service, and internal communication provide incredible convenience and efficiencies. At the same time, they create new opportunities for malicious interference through multiple points of entry. The 2025 ransomware attack on British retailer Marks and Spencer (M&S) illustrates the potential impacts of such an incident on major business functions.

The ransomware attack of 2025 resulted in restrictions to a critical number of M&S's online functions related to ordering and partially disrupting supply-chain and warehousing processes. The affected systems had to be taken offline during the incident investigation and resolution. Furthermore, the attack raised concerns about the security of customer data and privacy. Finally, the involvement of a third-party contractor in the attack underscored challenges with technology security and dependencies. By implication, the key problem that this case study addresses is the vulnerability of large-scale interconnected retail organizations and their operations to ransomware attacks. In particular, the case examines the ransomware attack on M&S, beginning with the way in which the perpetrators accessed the system. Furthermore, the case asks how the attack impacted the broader functioning of the business and what operational and technological response to the incident had been deployed. Ultimately, it is important to understand the vulnerabilities and risks that were exposed by the attack. This knowledge will inform the key topics that the case study will address.

CASE DESCRIPTION

The cyberattack on Marks and Spencer (M&S) in 2025 has turned out to be one of the most damaging cyber-incidents that shook a big UK retailer in the past quarters. As M&S entered the 2025/26 financial year, its performance remained strong, but the situation changed quickly, as the retailer reported a “sophisticated and targeted cyber incident.” The threat started in April 2025, and the attack surface of M&S was forced to make choices about what systems needed to remain connected during the incident investigation.

Discovery and Initial Response:

M&S publicly announced the cyber incident in April 2025. However, instead of letting all its operations run as usual, as expected, the company took a few precautions to mitigate the possible danger to its continued operations. Some of its processes were shifted to offline, and the company brought in outside cybersecurity experts to help deal with the problem. Additionally, M&S's long-standing business-continuity and incident-management procedures were deployed. The initial response created immediate challenges for the company, as the management had to strike a delicate balance between focusing on its business needs and protecting its customers' data. As such, on 23 April, the company announced that while its stores were open, some services had been disrupted and contactless payments had been suspended. Furthermore, the Click & Collect service was also closed, and some delivery services faced delays. On 25 April, M&S announced further disruptions to its business as it tried to protect customers' data by halting the cyber attackers from reaching it. As such, the company closed its website and applications to new orders. While the site remained open for browsing, the company's physical stores continued to operate. However, the closure was not a complete closure of the company's retail operations but rather a temporary measure for the company to mitigate the effects of the cybercrime it was facing.

How the Attack Evolved:

As more information about the attack emerged, the actual scope of the attack became apparent. In a technology-driven environment such as the company's IT infrastructure, the risk was not only limited to the affected application or website. In other words, securing the latter often involved taking action across the company's entire ecosystem. M&S's warehouse-management

system was disconnected, disrupting the supply chain and, by extension, the company's ability to deliver goods to the consumers. The company had to implement manual processes for supply chain management and forecasting, order fulfillment, and replenishment. The case also highlighted the potential risk posed by the company's technology ecosystem. M&S had previously acknowledged that its reliance on external organizations could jeopardize its information security. In particular, the company's risk assessment report noted the threat posed by cybersecurity incidents targeting not only M&S but also other entities in its ecosystem, leading to information security breaches, operational disruptions, and reputational damage. Most importantly, subsequent reports suggested that the attackers were able to gain access to the network via a third-party contractor. In many ways, this information became the focal point of the case, highlighting the fact that the security of an organization's own IT infrastructure could be compromised due to the weak links in its extended technology ecosystem. Among the key cybersecurity topics related to the case are third-party risk, identity security, social engineering, monitoring, and control, and supply chain management.

Groups Associated with the Attack:

The identities of those behind the attack were not established at an early date – indeed, media speculation first linked the assault with Scattered Spider, a loose confederation of cybercriminals reportedly tied to a number of major attacks, but this was not accurate. In the UK, M&S chairman Archie Norman gave evidence to the Business and Trade Committee of the House of Commons in July 2025, stating that the company suspected the ransomware campaign which caused the attack to be associated with DragonForce. Norman described these criminals as 'loose', and suggested that M&S believed DragonForce to have 'led the attack'. Scattered Spider, however, is commonly associated with ransomware campaigns in which multiple gangs collaborate or employ the services of other criminal groups. It is possible, even likely, for multiple ransomware gangs to utilise the same ransomware infrastructure and operational services. Therefore, it must be stressed that this should not be considered an entirely conclusive attribution of the attack to any one group and their specific methods – in public statements, the media has linked Scattered Spider with the overall intrusion set, yet M&S later confirmed that DragonForce was the ransomware operation it attributed to the attack. For the purposes of this case study, therefore, it is best to refer to this as a ransomware incident which M&S attributed to the DragonForce operations, with various other ransomware groups reported as participating in the attack chain.

Impact on Online Retail:

One of the most obvious impacts of the attack was on M&S's online retail sales. The company was unable to operate its normal online ordering service for some time while its systems were investigated and rebuilt. Online clothing orders eventually resumed on 10 June 2025, so the disruption to orders lasted roughly 46 days. The impact extended beyond the ability of customers to place orders. The temporary loss of critical systems impacted stock movement, fulfilment and other processes supporting online sales. M&S had to deal with a staged recovery rather than just switching its website back on. Its later reporting noted that customer-facing systems were progressively restored and that the online offer was fully restored in August. This extended interruption shows an important characteristic of ransomware incidents: the visible problem experienced by customers is only one part of a much larger technical recovery process. After an organisation identifies and contains an attack, it may well need to rebuild applications, restore networks, verify systems and slowly reconnect third-party services before normal

operations can safely resume. M&S reported that some applications and file systems had to be rebuilt because they were not recoverable in their existing state.

Customer Data and Privacy Concerns:

The incident also caused a data-security issue. M&S later warned its customers that certain personal information may have been compromised during the attack. This information included contact details, dates of birth and online order details. However, M&S explained that the compromised information does not contain useful payment-card details or account passwords. The company also clarified that there is no indication that the stolen information had been shared. The data aspect of the incident was significant as it added a privacy angle to an incident that was already disrupting business operations considerably. A ransomware incident can therefore involve multiple risks at once – causing systems to be unreachable, data to be stolen, services to be unavailable and regulatory, financial and reputational issues to arise for the organisation involved.

Effect on Food and Supply-Chain Operations:

M&S's food business also suffered from the attack's aftermath. Disconnected warehouse-management systems and the shift toward manual processes impacted the company's demand-forecasting, ordering capabilities, and overall replenishment. M&S noted a reduction in food availability, higher waste levels, additional costs from logistics during the downtime, and several other problems related to the incident. The company nonetheless continued operating its physical stores, as its staff implemented alternate procedures to enable trading while the technological tools were being re-established. At the same time, the company's technology workers focused on bringing critical systems back online, which was an essential component of its business-continuity strategy. The company's incident thus impacted the interrelation between its technological tools and physical presence. A customer that shops at an M&S store may still be able to make purchases, but the supply chain, warehousing, inventory, and ordering systems have all been affected. The case illustrates how a cyberattack targeting digital infrastructure can disrupt physical retail operations by impacting their supply chains and warehousing.

Financial Consequences:

The cost of the disruption to the business's operations was significant. In its 2025 report, M&S estimated that the event could have an impact of roughly £300 million on the group's profits for the 2025/26 fiscal year, although the actual impact will depend on various factors, including insurance, cost control and other management actions. The financial results showed a significant cost impact on the business. M&S reported that the first half of 2025/26 was significantly impacted by the cyber incident and reported £101.6 million of costs related to the incident during that period. The company's full-year 2026 results later reported £131.3 million in incident-related costs, including system recovery, risk-management and specialist advisory expenses. M&S also recorded £100 million in insurance proceeds related to the incident. These figures show that the financial consequences of ransomware are far more than the potential ransom demand. An organisation can incur costs related to system recovery, specialist assistance, lost sales, operational inefficiency, additional logistics, wasted stock, customer compensation, insurance arrangements and long-term technology improvements.

Recovery and Strengthening of Technology:

After the attack, M&S focused on restoring its technology environment. The company worked with specialist organizations to rebuild the affected systems and gradually re-established networks and applications. Another element of the recovery strategy was to accelerate the development of technology improvements that had already been planned before incident. The company used the incident to drive investment in its infrastructure, network connectivity, store technology and supply-chain systems. The stated objective was not only to return to the previous technology environment but also to create a less complex architecture in which systems are less reliant on each other and more resilient. By the second half of 2025/26, M&S reported that it had recovered practically all of its operational systems and that it had restored its customer-facing systems. The company continued to work on resilience and technology transformation beyond the immediate crisis.

Overall Case Significance:

The M&S ransomware case is a prime example of how a cyberattack could have evolved from an initial breach into an all-encompassing business crisis. While the attack's effects seemingly started in the sphere of cybersecurity, they soon spread to the company's ability to operate as normal. Notably, the ransomware impacted not only the retail stores' physical operations but also the online business, inventory, supply chains, customer data, finances, and overall reputation. The fact that the company's systems had to be shut down to eliminate the threat also shows how challenging it can be to balance external operations and internal security in the face of such an attack. Perhaps, the most significant lesson that the M&S ransomware case teaches is that businesses should consider cybersecurity not as an exclusive responsibility of their IT departments but as a broad corporate-level responsibility. While M&S management seemed to be well aware of the ransomware threat before the attack, the event showed that such situations are much harder to navigate than theory suggests. The attack aftermath also serves as a somber reminder that, for big companies, ransomware is rarely a one-time event. One has to remember that, in the case of M&S, weeks of continuous operations disruptions were necessary to restore the IT infrastructure, inspect and re-install software, resume supply chains, address customer concerns, and return to normal operations.

TECHNICAL ANALYSIS:

Unlike other incidents, the 2025 cyberattack of Marks and Spencer (M&S) appears to be a multi-stage attack in which hackers used access connected to one source to target a different third-party organisation before moving to cause damage to M&S's technology environment. Whilst the company has not disclosed a technical breakdown of every action performed by the attackers, the information released during the course of the investigation provides an overview of major steps undergone during the attack.

Initial Access and Third-Party Compromise:

The technical aspect of the attack highlights that it involved a third-party contractor. In other words, the breach was not in M&S's public IT infrastructure but a software application belonging to one of the companies working with M&S. The attack surface involved third-party or supply chain risk, which refers to a scenario where adversaries target a weaker link in the

security chain to reach a primary objective. It is reported that the infiltration involved social engineering. Social engineering is a form of manipulation aimed at gaining unauthorized access to data, systems, or physical locations by exploiting human psychology rather than technical loopholes. It is particularly concerning because successful social engineering attacks often appear legitimate to the defenders, making them challenging to detect and respond to in a timely manner. The incident therefore proves that an organisation's security perimeter does not end at the edge of its network. Contractors, suppliers, and technology partners can contribute to the attack surface if they have access to a protected application or business system.

Access to Systems and Internal Disruption:

After gaining access, the attackers managed to penetrate further into the extended technology environment. Since the inner workings have not been publicly disclosed, postulation on the specific vulnerabilities or hacking tools would be speculative. However, the fact that disruptions have occurred suggests that the attackers impacted systems supporting key business processes. M&S had to segment parts of their technology environment in order to contain the breach. These included warehouse-management systems which impacted downstream processes, including forecasting, ordering and replenishment. Some of these procedures had to be carried out manually as the affected systems were being reinstalled. This serves as a lesson on the need for network segmentation and access control. Within an extended and interconnected environment, a successful breach of one account can create a springboard into other systems and data. Segmenting systems and limiting access based on business needs can help in containing the damage and curtailing lateral movement by the attackers.

Data Theft and Ransomware:

The breach involved both data confidentiality and system's availability since M&S confirmed that some customer information was obtained by hackers during the attack. Specifically, the category of data which was at stake comprised contact details, dates of birth and online order history, whilst the company stated that the ransomware operators did not utilize any of the customers' payment-card information or account passwords. It is noteworthy that the ransomware itself called DragonForce and the whole attack was attributed to the DragonForce group. M&S chairman Archie Norman stated that the company assumed that DragonForce was behind the ransomware campaign. Previously, the wider attack was linked to Scattered Spider, yet the specific role of each collective/group is still not completely clear. Indeed, from a technical perspective, the case exemplifies the double-edged nature of contemporary ransomware attacks. Specifically, attackers might aim to utilise valuable information which is stored in organisation's databases, yet simultaneously such cybercriminals seek to disrupt the business processes by extortion. Accordingly, organisations need to simultaneously address the data confidentiality and system availability in order to avoid severe losses.

Containment and Recovery:

M&S isolated affected systems and limited the use of some digital services. The online ordering systems were shut down for an extended period, while stores were kept open and operating with alternate procedures. The company's technologists and external experts worked together to identify the affected systems and respond to the ransomware by isolating and recovering the organization's systems. The ransomware incident's aftermath is substantially more complex and time-consuming than removing malware from the systems. It is necessary to assess all systems for possible compromises, respond to unauthorized data access attempts, and ensure

the integrity of the restored data before reconnecting them to the main system. M&S reported that certain applications and file systems needed rebuilding, while others were gradually recovered. The ransomware attack also highlighted the importance of having alternate procedures in place, allowing the business to continue operating in a limited capacity. While the isolated systems were shut down and the online systems were taken offline, the manual procedures allowed to keep some retail stores open.

Key Technical Lessons:

The case of M&S offers a number of vital cybersecurity insights. Firstly, third-party software and hardware must be viewed as an important element of an organisation's security infrastructure, not as a separate area of potential breaches. Secondly, there must be reliable safeguards against impersonation and social engineering and stringent identity verification procedures within any given account, since infiltration by way of third-party access usually serves to provide a vector to a broader attack. Thirdly, network segmentation and the least-privilege principle should be applied to reduce the impact of a possible breach. Lastly, reliable backdoors, incident-response mechanisms and business continuity plans should be designed to ensure rapid recovery and uninterrupted operations in case of an exfiltration or attack. Overall, the case of M&S demonstrates that the ransomware attack is more than just a computer issue. The attack impacted multiple spheres in the organisation, beginning from third-party access and customer data exfiltration, proceeding to the digital services disruption and warehouse management incompatibility and ending with the system recovery. In this sense, the most significant technical lessons concern the importance of designing a comprehensive cybersecurity framework with multiple protection layers, ranging from zero-trust access control and regular monitoring to network segmentation, incident response and backup systems.

IMPACT ANALYSIS:

The ransomware attack not only impacted organizational processes of Marks and Spencer (M&S). Being highly digitized and relying on technology for most of its operations, including online sales, inventory management, and communication, the company was affected in multiple ways. Thus, the ransomware attack had operational, financial, customer, data-security, and reputational effects.

Operational Impact:

In one of the short-term impact areas, operational impact, M&S's online operations were disrupted due to the attack. The company was forced to halt taking any online orders until the situation was brought under control. This caused significant inconvenience to the customers who had to rely on websites and apps to fulfill their needs. They turned to physical stores even more, putting extra strain on them. In addition, the warehouses and supply chains were also disrupted, and some operations had to be done manually, complicating the process of ordering and stocking of goods. The attack highlighted the extent to which M&S had integrated digital technology into its business practices and procedures. Even though no damage was done to physical stores, they still had to endure the consequences of the breach and the following chaos.

Financial Impact:

The attack has resulted in significant financial losses to M&S. The business lost revenue from online sales, incurred expenditures and additional costs related to cybersecurity specialists, system restoration, and technology recovery. The impact on food operations added waste and logistic costs. In the initial assessment, the M&S group expected that incident would trim twenty-five percent of this year's group profit, or about £300 million. However, later reports showed significant costs incurred due to the ransomware attack, although the insurance covered some expenses. Thus, the ransomware costs could go far beyond the initial expectations affecting the profit for the 2025/26 significantly.

Customer and Data Impact:

Customer experience was also impacted as customers were unable to make purchases conveniently online due to the system malfunction and some of them lost the ability to use collection and delivery services. Another privacy concern was raised as it was reported by M&S that some customers' data was compromised. The compromised information included contact details, dates of birth, and online purchase history, although the message highlights that card payment details and passwords to their accounts were secure. Even though the loss of contact details and purchase history does not involve the exposure of highly sensitive information, it poses a privacy and security risk to customers.

Reputational impact:

One of the indirect costs of a significant cyberattack is the damage to the organization's reputation as a competent entity that can adequately protect its data and systems. The attack's aftermath resonated with M&S customers, employees, suppliers, and investors. In particular, the company had to constantly address the resulting issues and respond to customer concerns about the attack's consequences. Moreover, the incident highlighted the potential reputational risks associated with the organization's reliance on subcontractors. The attack was enabled by a vulnerability stemming from a third-party company, which means that it could have been averted if M&S had not relied on an external provider.

Overall Impact:

Overall, the impact of the M&S ransomware attack was significant on the business, including financial, customer services, data, and reputation costs. The case is notable because the attack on the company's IT system led to real-life business impacts, including disruption of stores, warehouses, supply chains, and customer services. It showed that responding to ransomware demands is a business issue, not just an IT issue. The case also reveals the importance of third-party security, incident-management procedures, recovery systems, and business continuity management. For firms of a similar scale, preparing responses to potential long-term technology interruptions is critical in lessening the impact of a ransomware attack.

SOLUTION/COUNTERMEASURES:

The M&S ransomware case is a vivid illustration of the fact that big companies need to create security measures for not only their internal systems but also the external ones connected to them. The following countermeasures can be implemented to mitigate the risks posed by the ransomware attack:

- **Strengthen third-party security:** M&S should periodically assess suppliers and contractors, restrict their access to only the systems necessitated, and continually review third-party accounts.
- **Improve identity protection:** Robust multifactor authentication, phishing resistant authentication and constant monitoring of anomalous login activity can mitigate the risks of compromised credentials being misused.
- **Use network segmentation:** Crucial systems such as the warehouses, customer databases and business applications need to be partitioned such that the compromise of one does not easily extend to the others.
- **Maintain reliable backups:** Vital systems and data need to have secure, regularly tested backups that are segregated from the main network. This can ease the restoration process if systems happen to be unavailable.
- **Strengthen incident-response planning:** Organisations should test out their response procedures through realistic exercises so that technical teams and business departments know what to do during an attack.
- **Improve monitoring and detection:** Constant surveillance of internal systems, privileged accounts and third-party connections can facilitate with early identification of anomalous behaviour.
- **Build stronger business continuity:** Alternative procedures should be worked out for essential activities so that important operations can continue on while the affected technology is being restored.

M&S itself hastened the investments in infrastructure, network connectivity, supply-chain systems and technology resilience after the incident. Its experiences show that cybersecurity should be seen as an organisational responsibility that needs to be a continuous effort rather than a once off technical measure.

FINDINGS & DISCUSSION:

The analysis of the Marks and Spencer (M&S) ransomware incident demonstrates the complexity of not only the ransomware itself but also the attack chain and the breach of the organisation's security measures. The report highlights several major points that comment on the current state of computer security within large-scale organisations, namely the interconnectivity of third-party networks, human factors and the dependency of businesses on the digital environment. One of the most important conclusions demonstrated by the article is the role of third-party organisations in network security. Indeed, the very fact that the ransomware attack could originate from a third-party contractor indicates that the attackers might have gained access to M&S data through another company. As such, it is evident that other firms and organisations are integral to the security of one's own network and data. Therefore, their security must be reviewed and monitored constantly, not only at the initial stage of cooperation. The case also revealed the significance of the concept of identity and access management. For instance, the report mentions that the attackers used social-

engineering methods to gain access to information and systems. In turn, this implies that most cyber-attackers target a company's employees and their actions as the entry point into the firm's data rather than technological weaknesses. As such, it is essential for organisations to ensure strong authentication, reduce personnel privileges to the barest minimum necessary for their operations, and monitor any anomalous activities to prevent data theft. Another insight from the case is that ransomware attacks can cause extensive disruptions to a firm's operations. According to the report, the cyber-attack not only halted the online ordering system but also the warehouse and supply chain management. This indicates the extent to which computer technologies are intertwined in the modern supply chains. In other words, the attack caused operational disruptions despite the stores remaining open to customers. The incident also serves as a reminder that the ability to continue business-critical activities, even during system outages, is essential. M&S used manual processes to preserve key operations, which suggests that organisations should consider having alternative approaches for their most important activities, rather than relying on the assumption that technology will always be available. From a financial perspective, the case shows the extended costs that can be incurred by ransomware beyond simply repairing the affected computers and servers. Loss of sales, specialist support and rebuilding costs, disruption to operations and additional logistic costs can all add significantly to the cost of an incident and should be considered as part of an organisation's overall risk assessment. The approach of the organisation to customer information illustrates another aspect of importance. Whilst M&S has stated that useful payment-card details and account passwords were not compromised, other elements of customer information were taken, which causes both an availability risk (to the organisation's systems) and a privacy risk (to customers' personal information). Organisations should consider availability and privacy as interrelated areas that should both be considered in their security planning.

Overall, the results suggest that no countermeasure alone can ensure protection of a large entity from ransomware. Instead, a system with many elements, including third-party risk management, secure authentication, restricted access, network segmentation, monitoring, backups, incident-response readiness and business continuity protocols, is necessary. The M&S case demonstrates that the resilience of cybersecurity infrastructure can be measured by its ability to prevent an attack, limit its impact, maintain critical functions and restore the system safely.

Thus, the incident serves as a valuable takeaway for other large entities, as the experience suggests that cybersecurity should be considered not as the exclusive responsibility of the information technology department, but rather as a matter of business continuity.

RECOMMENDATIONS:

In light of the above M&S ransomware case analysis, there are a number of suggestions that big organizations may want to take into consideration to either prevent or at least minimize the damage caused by the possible attack:

1. The cybersecurity of the organization depends largely on the cybersecurity of third parties providing external services. Therefore, it is crucial to evaluate the cybersecurity maturity of any external providers and make sure they are following safe and updated cybersecurity practices.

2. Multi-factor and phishing-resistant methods of authentication have to be applied to all users, including third parties, and weak authentication mechanisms have to be removed completely.
3. The principle of least privilege has to be respected, and inactive accounts that lost their authorization have to be immediately deleted or disabled.
4. Different important software solutions, such as databases, warehouses, and financial applications, have to be isolated from each other.
5. The data has to be backed up regularly, and those back-ups have to be regularly tested for corruption and usability in case of an emergency situation.
6. It is crucial to monitor all abnormal activity, including unsuccessful login attempts, unauthorized access to the system by third-party accounts, and other possible attacks.
7. All personnel, both employees and partners, have to be trained to recognize phishing and social engineering attacks.
8. Simulated ransomware situations have to be arranged to check the organization's preparedness for zero-day attacks.
9. Alternative procedures have to be developed for performing all critical functions without relying on existing computer technologies if the latter are disabled by the attack.
10. Finally, the reaction to the ransomware situation has to be analysed in order to determine which response methods worked and which did not after all attacks have been neutralized.

In summary, the ten recommendations above demonstrate that responding to the ransomware threat requires a multi-faceted approach that includes prevention, detection and immediate response, recovery, and business continuity.

CONCLUSION:

The Marks and Spencer ransomware incident demonstrates that these types of attacks can have serious repercussions both for the company concerned and for society as a whole. In this instance, the ransomware attack affected the company's online services and also caused disruption to its warehouses, resulting in major financial losses and the theft of customers' data. As the case makes clear, organisations must realise that the security of their own data and systems is only as good as that of their suppliers and contractors. Furthermore, the ransomware situation shows that attackers may do more than just encrypt data and ask for a ransom; they may also steal data which is important for the continuous operation of the company in question. Even though the ransomware demanded that a ransom should be paid, M&S was able to get rid of the attack and safeguard its data. The attack had an effect on the company's online services and caused a disruption to global supply chains as well as leading to the theft of customers' data. Yet the M&S ransomware case is an example of how a company can get back to normal operations after suffering such an attack. Even though the attack disrupted M&S's online services and supply chains, it did not cause the closure of its stores. Events such as the ransomware attack on M&S do, however, highlight the need for effective cybersecurity policies and response teams in order to deal with incidents quickly and efficiently. Businesses should adopt a multi-layered cybersecurity strategy which includes the use of strong authentication procedures, reducing third-party risk, network segmentation, monitoring and detection tools,

regular data backups, employee training, and incident response and recovery playbooks. Moreover, companies should regard cybersecurity as a business priority rather than merely as an IT issue. The M&S ransomware case shows that cybersecurity is not just about preventing attacks but also about making sure that, in the event of an incident, the business can carry on operating normally, protect the privacy of customers and other stakeholders, and be able to recover as quickly as possible.

REFERENCES:

- [1] Marks & Spencer, “Cyber Incident – Further Update,” Marks & Spencer Corporate Website, Apr. 23, 2025.
- [2] Marks & Spencer, “Cyber Incident – Further Update,” Marks & Spencer Corporate Website, Apr. 25, 2025.
- [3] Marks & Spencer, “Cyber Update,” Marks & Spencer Corporate Website, 2025.
- [4] Marks & Spencer Group plc, “Full Year Results for the 52 Weeks Ended 29 March 2025,” Marks & Spencer, May 2025.
- [5] Marks & Spencer Group plc, “Annual Report and Financial Statements 2025,” Marks & Spencer, 2025.
- [6] Reuters, “After 46-day cyberattack pause, M&S resumes online orders,” Reuters, Jun. 10, 2025.
- [7] Reuters, “M&S believes DragonForce behind ransomware attack, says chairman,” Reuters, Jul. 8, 2025.
- [8] Marks & Spencer Group plc, “Half Year Results for the 26 Weeks Ended 27 September 2025,” Marks & Spencer, Nov. 3, 2025.
- [9] Marks & Spencer Group plc, “Full Year Results for the 52 Weeks Ended 28 March 2026,” Marks & Spencer, May 2026.
- [10] Marks & Spencer Group plc, “Annual Report and Financial Statements 2026,” Marks & Spencer, 2026.